

Modulo 10

Framework di AI governance per il credit scoring

CrediPulse S.p.A., credito digitale a PMI e microimprese: modello operativo di governance, mappatura dei rischi, simulazione di conformità AI Act e template di accountability (RACI, Risk Register, Model Card, FRIA)

Governance, Etica e Compliance dell'AI

Simone La Porta

Master AI Solutions Architect - ProfessionAI

Indice

1. Executive summary	3
2. Contesto, caso d'uso e classificazione	3
2.1 CrediPulse e il sistema di scoring	3
2.2 Classificazione ai sensi dell'AI Act	4
2.3 Ambito ed esclusioni del framework	4
3. Quadro normativo di riferimento	5
3.1 AI Act: la spina dorsale	5
3.2 GDPR: il trattamento sotto il sistema	6
3.3 Disciplina finanziaria: EBA e DORA	6
3.4 Framework volontari: ISO/IEC 42001 e NIST AI RMF	7
4. Principi di governance	7
5. Modello operativo di governance	8
5.1 Organi, ruoli e linee di difesa	8
5.2 Ciclo di vita del modello e gate	9
5.3 Matrice RACI del ciclo di vita	10
6. Mappatura dei rischi	11
6.1 Metodologia	11
6.2 Le dieci categorie di rischio	12
6.3 Vista d'insieme e priorità	15
7. Simulazione di analisi di conformità (AI Act)	17
7.1 Metodo e stato di partenza ipotizzato	17
7.2 Obblighi da provider	17
7.3 Obblighi da deployer e tutele verso i richiedenti	18
8. Documentazione di accountability	19
8.1 L'architettura documentale	19
8.2 Model Card: uso e ciclo di aggiornamento	20
8.3 FRIA: processo e criterio di qualità	20
9. Monitoraggio, indicatori e incidenti	20
10. Roadmap di adozione e criteri di successo	21
11. Limiti del framework e follow-up	22
Appendice A - Template RACI e matrice dei ruoli	23
Appendice B - Template del Risk Register	23
Appendice C - Template della Model Card	24
Appendice D - Template della FRIA	25
Appendice E - Model Card compilata: CS-PMI v3.2	26
Appendice F - FRIA compilata: sistema di scoring CS-PMI	27

1. Executive summary

CrediPulse S.p.A. eroga credito digitale a PMI e microimprese usando un sistema di scoring automatico che combina dati transazionali, contabili, comportamentali e alternativi per decidere approvazioni, rifiuti e offerte condizionate, per prezzare il rischio e per monitorare il portafoglio. Questo documento definisce il framework di AI governance che rende quel sistema governabile e difendibile: il modello operativo con ruoli e responsabilità, la mappatura dei rischi nelle dieci categorie richieste dalla traccia, una simulazione di analisi di conformità all'AI Act con gap e owner assegnati, e i template di accountability (RACI, Risk Register, Model Card, FRIA) pronti all'uso, con Model Card e FRIA anche compilate sul modello di scoring. Il destinatario della prima approvazione è il Consiglio di amministrazione; i destinatari d'uso sono le funzioni che il framework nomina.

Quattro conclusioni orientano tutto il resto. Prima: il sistema è AI ad alto rischio per la via più diretta possibile, la valutazione del merito creditizio è nell'Annex III e la profilazione esclude ogni eccezione; CrediPulse, che sviluppa in casa e usa per sé, cumula gli obblighi del provider (artt. 8-20, 43-49, 72-73) e del deployer (artt. 26-27, 86), FRIA inclusa. Seconda: la governance non parte da zero; il model risk management del credito, la certificazione ISO/IEC 27001 e i processi DORA esistenti coprono più strada di quanto sembri, e il framework li estende invece di duplicarli. Terza: il rischio dominante non è tecnico ma di equità, la discriminazione algoritmica per proxy, col suo doppio fallimento di esclusione finanziaria e sovraindebitamento; è l'unico rischio a priorità critica del registro. Quarta: il calendario non concede margini, gli obblighi per i sistemi ad alto rischio si applicano dal 2026-08-02; la simulazione di conformità del capitolo 7 è, nei fatti, il piano di lavoro dei prossimi mesi.

Il criterio con cui giudicare questo framework è dichiarato nel capitolo 4 e vale la pena anticiparlo: non la completezza dei diagrammi ma la capacità di incidere. Un framework che non ha mai cambiato, ritardato o fermato un rilascio non sta governando niente; è la versione organizzativa di una polizza mai riscossa, e per un'azienda che decide del credito altrui con un algoritmo sarebbe un lusso fuori portata.

2. Contesto, caso d'uso e classificazione

2.1 CrediPulse e il sistema di scoring

CrediPulse è una fintech di credito digitale per PMI e microimprese: circa 120 dipendenti, canale interamente online, nell'ordine delle decine di migliaia di pratiche l'anno. Il caso d'uso primario di questo framework è il modello di scoring CS-PMI, in produzione dal 2024, che per ogni richiesta di finanziamento produce una valutazione del rischio e una raccomandazione operativa: approvazione, rifiuto o offerta condizionata (importo ridotto, garanzie, pricing rivisto). Lo stesso motore alimenta il pricing e il monitoraggio continuo del portafoglio. Le fonti dati sono quattro, con profili di rischio diversi: dati transazionali bancari via open banking, dati contabili dai bilanci depositati, comportamento digitale nel funnel di richiesta, e fonti alternative (segnali pubblici sull'impresa, dati settoriali). Le decisioni sotto la soglia di confidenza definita vanno a istruttoria manuale; il resto del flusso è automatico con revisione a campione.

Modello	Funzioni coperte	Classificazione AI Act	Proprietario
CS-PMI (MDL-2024-003)	Scoring delle richieste; pricing; monitoraggio del portafoglio (stesso motore)	Alto rischio - Annex III, punto 5(b)	Model Owner

Tabella 1 - Inventario dei modelli in perimetro, con classificazione e proprietario.

Il peso aziendale del sistema è la ragione di questo documento: il modello agisce su tassi di approvazione, pricing, accantonamenti e reputazione. Un suo errore sistematico non è un bug, è una politica commerciale sbagliata applicata a migliaia di imprese; una sua opacità non è un difetto estetico, è un rischio legale con richiedenti, Garante e autorità di vigilanza come controparti.

2.2 Classificazione ai sensi dell'AI Act

La classificazione è una procedura documentata, non un'opinione, e va eseguita in ordine. Primo: il sistema è AI ai sensi dell'art. 3(1), un sistema basato su macchina che inferisce dagli input come generare punteggi e raccomandazioni; non è un motore di regole scritte a mano. Secondo: non ricade nelle pratiche vietate dell'art. 5; in particolare non è social scoring, che il divieto colpisce quando la valutazione produce effetti in contesti slegati da quello di raccolta, mentre la valutazione settoriale del merito creditizio è esplicitamente instradata nel regime ad alto rischio. Terzo: nessun aggancio all'Annex I, il sistema non è componente di sicurezza di un prodotto regolato. Quarto: l'Annex III, punto 5(b), copre esattamente questo uso, l'accesso ai servizi privati essenziali attraverso la valutazione dell'affidabilità creditizia. Quinto: le eccezioni dell'art. 6(3) non sono invocabili, perché il sistema esegue profilazione di persone fisiche (titolari effettivi e garanti dietro le imprese) e la profilazione chiude ogni uscita per costruzione. Conclusione: AI ad alto rischio, regime pieno.

Sui ruoli: CrediPulse sviluppa il modello in casa e lo usa nei propri processi, quindi è provider e deployer dello stesso sistema. La distinzione non è accademica: da provider deve soddisfare i requisiti sostanziali e il percorso di conformità (artt. 8-20, 43-49, 72-73), da deployer deve usare il sistema secondo le istruzioni, monitorarlo, garantire le salvaguardie verso i richiedenti e condurre la FRIA, che per la valutazione del merito creditizio è uno dei due soli casi privati obbligati dall'art. 27. L'art. 25 aggiunge un confine da presidiare nel tempo: se in futuro CrediPulse offrisse il motore in white-label a terzi o modificasse sostanzialmente componenti acquistati, il perimetro degli obblighi si ridisegnerebbe.

Perché la classificazione è essa stessa un controllo

La tentazione ricorrente nei progetti AI è trattare la classificazione come una valutazione informale da riunione tecnica. L'AI Act la tratta come un atto formale: l'eventuale eccezione ex art. 6(3) va valutata e documentata prima dell'immissione sul mercato (art. 6(4)), con registrazione del sistema (art. 49), e una classificazione errata è una violazione autonoma, non un'attenuante. Per questo il framework colloca la classificazione nel gate G0, con esito verbalizzato: è il primo punto in cui la governance può dire no.

2.3 Ambito ed esclusioni del framework

Il framework copre i sistemi AI di scoring, pricing e monitoraggio del rischio creditizio, i processi di governance correlati (ruoli, accountability, documentazione), la mappatura dei rischi nelle categorie richieste e la simulazione di analisi di conformità per il sistema ad alto rischio, con i template di documentazione in appendice. Restano fuori, per scelta della traccia e coerenza con la natura di governance del documento: le implementazioni tecniche, la selezione o il tuning di algoritmi, i dettagli di integrazione nei sistemi di produzione e le tecniche concrete di mitigazione (preprocessing, vincoli di fairness, architetture). Dove il confine è sottile, ad esempio sulle metriche di equità, il framework fissa il requisito e l'accountability della scelta, non la tecnica.

3. Quadro normativo di riferimento

Cinque corpi normativi guardano lo stesso sistema da angoli diversi. La figura 1 li dispone intorno al sistema di scoring; il capitolo li percorre in ordine di forza vincolante.

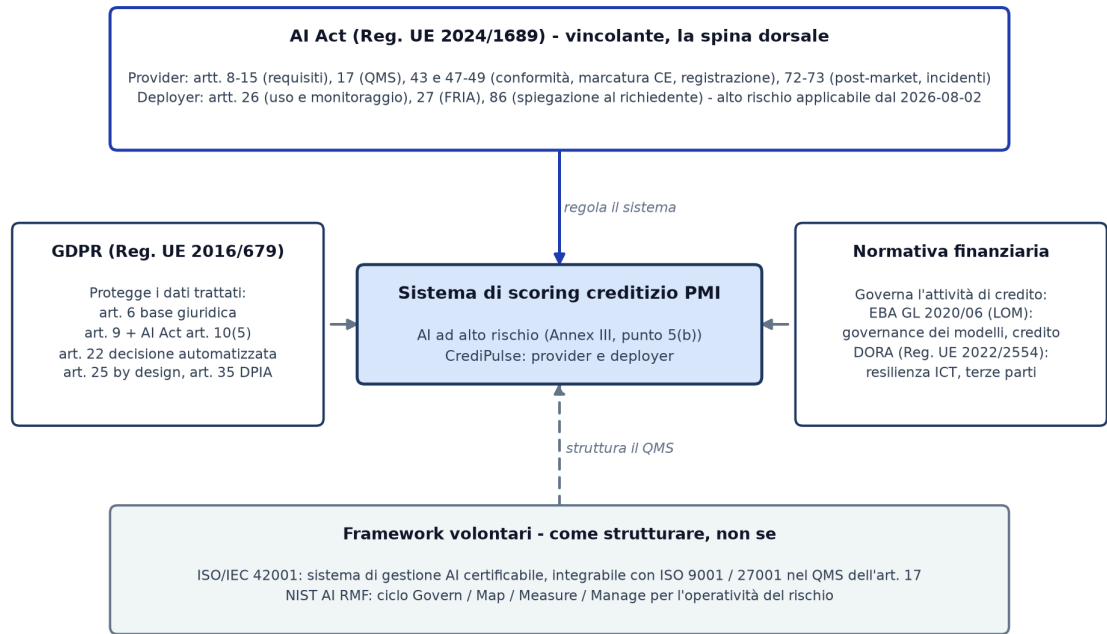


Figura 1 - Il quadro normativo intorno al sistema di scoring: AI Act come spina dorsale, GDPR sui dati trattati, disciplina finanziaria sull'attività di credito, framework volontari come struttura del sistema di gestione.

3.1 AI Act: la spina dorsale

L'AI Act (Reg. UE 2024/1689) è un ibrido riuscito: la macchina di enforcement della normativa di prodotto europea, caricata con un payload di diritti fondamentali. Per un sistema ad alto rischio gli obblighi del provider si leggono come una sequenza in cui ogni passo produce l'evidenza che il successivo consuma:

Fase	Obbligo	Riferimento	Artefatto prodotto
Progettare	Requisiti sostanziali: rischio, dati, doc, log, trasparenza, oversight, robustezza	artt. 8-15	Risk file, evidenze dati, log, istruzioni d'uso
Organizzare	Sistema di gestione qualità	art. 17	QMS documentato (integrato con i sistemi esistenti)
Documentare	Documentazione tecnica	art. 11, Annex IV	Il fascicolo che l'autorità legge per primo
Verificare	Valutazione di conformità	art. 43	Controllo interno (Annex VI) per il credit scoring
Dichiarare	Dichiarazione UE e marcatura	artt. 47-48	Dichiarazione firmata, marcatura CE

Fase	Obbligo	Riferimento	Artefatto prodotto
Registrare	Banca dati UE	art. 49	Registrazione pubblica del sistema
Esercire	Monitoraggio post-market	art. 72	Piano e report che alimentano il ciclo art. 9
Reagire	Incidenti gravi e azioni correttive	artt. 73, 20	Segnalazioni nei termini, correzioni

Tabella 2 - La sequenza degli obblighi del provider per un sistema ad alto rischio.

Da deployer si aggiungono l'uso conforme alle istruzioni e il monitoraggio (art. 26), la FRIA prima della messa in servizio (art. 27) e, verso i richiedenti, il diritto a una spiegazione della singola decisione (art. 86). Il calendario è scaglionato e in parte già scaduto: divieti e alfabetizzazione AI si applicano dal 2025-02-02, le regole sui modelli general-purpose dal 2025-08-02, il grosso del regime ad alto rischio dal 2026-08-02. Alla data di questo documento la finestra si misura in giorni: ogni piano che rimandi la conformità a dopo l'estate è già in ritardo.

3.2 GDPR: il trattamento sotto il sistema

AI Act e GDPR si applicano in parallelo e non si assorbono: il primo regola il sistema come artefatto, il secondo i trattamenti di dati personali che lo attraversano. Un sistema marcato CE senza base giuridica resta illecito. Tre punti di contatto contano più degli altri per il credito. L'art. 22 GDPR dà al richiedente il diritto a non essere sottoposto a una decisione solo automatizzata con effetti significativi, e il rifiuto di credito è il caso di scuola: le eccezioni richiedono salvaguardie, intervento umano in testa, e un revisore che timbra le code del modello non soddisfa né l'art. 22 né l'art. 14 AI Act, mentre un intervento umano reale li soddisfa entrambi. L'art. 10(5) AI Act apre una porta stretta che il GDPR da solo teneva chiusa: trattare categorie particolari di dati proprio per rilevare e correggere i bias, con garanzie rafforzate. Infine la coppia DPIA-FRIA: l'art. 27(4) evita la duplicazione, la DPIA copre il trattamento, la FRIA allarga lo sguardo ai diritti fondamentali; il framework le tratta come un dossier coordinato sotto owner distinti. Sul fronte training, il parere EDPB 28/2024 fissa il metodo: legittimo interesse possibile ma con test di bilanciamento documentato, e un modello addestrato illecitamente può contaminare gli usi a valle.

3.3 Disciplina finanziaria: EBA e DORA

CrediPulse non incontra la governance dei modelli per la prima volta con l'AI Act. Le linee guida EBA su concessione e monitoraggio del credito (EBA/GL/2020/06) chiedono già governance dell'uso di modelli nel processo creditizio, qualità dei dati e capacità di spiegare le decisioni al cliente; DORA (Reg. UE 2022/2554) impone resilienza operativa digitale, gestione degli incidenti ICT e presidio delle terze parti critiche, categorie in cui pipeline dati e modello rientrano a pieno titolo. La conseguenza pratica la offre lo stesso AI Act: per gli istituti finanziari il sistema di gestione qualità dell'art. 17 può appoggiarsi alla governance settoriale esistente. La valvola ha però un perimetro preciso: l'art. 17(4) esclude espressamente la gestione del rischio (art. 9), il monitoraggio post-market (art. 72) e la segnalazione degli incidenti (art. 73), che restano da implementare in chiave AI, e infatti il capitolo 7 li tratta come voci autonome. Va dichiarata anche un'assunzione: lo scenario ipotizza che CrediPulse rientri tra gli istituti finanziari soggetti a requisiti di governance interna ai sensi del diritto UE dei servizi finanziari; su un'azienda reale la qualifica va verificata sul titolo abilitativo. Entro questi confini la scelta di fondo regge: un impianto solo, mappato su più regimi, invece di tre impianti paralleli.

3.4 Framework volontari: ISO/IEC 42001 e NIST AI RMF

I volontari non aggiungono obblighi, aggiungono struttura. ISO/IEC 42001 definisce il sistema di gestione dell'AI certificabile e si integra con ISO 9001 e ISO/IEC 27001: è la forma naturale del QMS art. 17, e la certificazione, quando arriverà il momento, sarà un segnale spendibile con partner bancari e vigilanza. NIST AI RMF organizza l'operatività del rischio nel ciclo Govern, Map, Measure, Manage, con Govern come fondazione trasversale e non come fase. La tabella 3 mostra come i processi di questo framework servano insieme i tre livelli.

Processo del framework	AI Act	ISO/IEC 42001	NIST AI RMF
Classificazione e inventario (G0)	artt. 6, 49	contesto e ambito AIMS	Map
Registro dei rischi iterativo	art. 9	valutazione dei rischi AI	Map / Measure
Data governance ed esame bias	art. 10	gestione dati e impatti	Measure
Gate di ciclo di vita e veto	artt. 14, 17	controlli operativi	Manage
Monitoraggio, KPI, post-market	art. 72	miglioramento continuo	Measure / Manage
Organi, ruoli, escalation	accountability provider	leadership e ruoli	Govern

Tabella 3 - Corrispondenza tra i processi del framework e i tre riferimenti.

Lettura critica. Cinque regimi sembrano un onere quintuplo e sono, letti bene, lo stesso impianto chiesto con lessici diversi: tracciabilità delle decisioni, governo dei dati, responsabilità nominate, gestione di incidenti e fornitori. La scelta di fondo di questo framework, estendere il model risk management del credito e la 27001 invece di costruire un sistema parallelo 'per l'AI', non è una scorciatoia: è l'unica configurazione in cui la conformità produce un solo corpus di evidenze riusabile con ogni interlocutore, e in cui il costo marginale di ogni nuovo modello decresce invece di crescere.

4. Principi di governance

Sei principi, scelti perché per ciascuno esiste un modo concreto di verificarne il rispetto. Ogni principio scende in almeno una policy, ogni policy in almeno un controllo con metrica e owner: è la catena che distingue la governance dall'ethics washing, e la tabella 4 la rende ispezionabile da un esterno.

- **Accountability nominata.** Ogni modello in produzione ha un Model Owner, una persona, non una funzione; nessun modello vive fuori inventario.
- **Equità dimostrabile.** La metrica di equità è scelta e motivata per iscritto a ogni modello; la fairness si misura disaggregata, non si dichiara.
- **Trasparenza a due livelli.** Il richiedente sa che uno scoring contribuisce alla decisione e riceve, per la sua pratica, motivi comprensibili e azionabili.
- **Supervisione umana effettiva.** Chi rivede le decisioni ha informazioni, tempo e autorità per ribaltarle; l'override è un esito previsto, misurato in entrambe le direzioni.
- **Tracciabilità end-to-end.** Ogni decisione è ricostruibile: input, versione del modello, score, esito, eventuale intervento umano. Requisito di prodotto, non di processo.

- **Proporzionalità e integrazione.** I controlli si innestano sui sistemi di gestione esistenti (model risk, 27001, DORA); la duplicazione è essa stessa un rischio operativo.

Principio	Policy	Controllo	Metrica	Owner
Accountability	Inventario obbligatorio dei modelli	Gate G0: nessun modello senza owner e classificazione	Copertura inventario 100%	Responsabile AI
Equità	Metrica di fairness scelta e motivata per modello	Gate G1-G2 e monitoraggio mensile disaggregato	Equal opportunity gap entro soglia	Model Owner
Trasparenza	Disclosure di sistema e spiegazione individuale	Template di motivazione per ogni causale di esito	Consegna spiegazioni; reclami per opacità	Business credito
Supervisione	Fascia grigia e autorità di override formalizzate	Design art. 14: informazioni, tempo, autorità	Override rate in banda attesa	Comitato AI Gov.
Tracciabilità	Logging decisionale completo (art. 12)	Requisito bloccante al rilascio (G3)	Copertura log decisioni 100%	Model Steward
Integrazione	Un solo impianto di gestione, mappato sui regimi	Revisione annuale del framework	Un unico corpus di evidenze per audit	Compliance

Tabella 4 - La catena principio, policy, controllo, metrica, owner.

5. Modello operativo di governance

5.1 Organi, ruoli e linee di difesa

L'architettura organizzativa porta nel mondo AI un modello che il settore finanziario conosce bene, le tre linee di difesa, e lo fa per una ragione precisa: risolve in anticipo le dispute di confine. La prima linea possiede i modelli e i rischi che generano; la seconda scrive le policy e sfida le scelte senza possederle; la terza dà assurance indipendente senza scrivere policy. Il rischio non possiede modelli, l'audit non scrive regole: quando queste due frasi sono vere, la governance ha smesso di essere un organigramma e ha cominciato a funzionare.

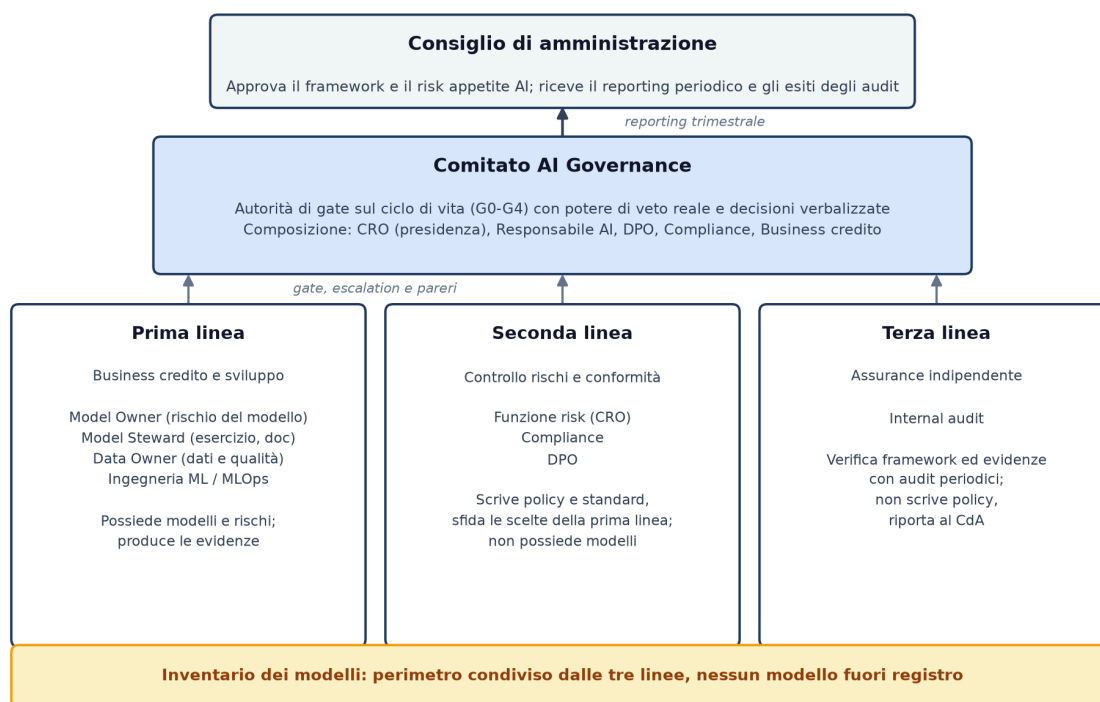


Figura 2 - Il modello operativo: Consiglio, Comitato AI Governance con autorità di gate, tre linee di difesa e inventario dei modelli come perimetro comune.

Il Consiglio di amministrazione approva il framework e il risk appetite AI e riceve reporting trimestrale; il criterio di successo della traccia, un framework approvato dal Board, è quindi un passaggio formale previsto, non un auspicio. Il Comitato AI Governance è l'organo esecutivo del framework: presiede i gate del ciclo di vita con potere di veto reale e decisioni verbalizzate, ed è composto da CRO (presidenza), Responsabile AI, DPO, Compliance e business credito. La composizione è una scelta deliberata: nessuna funzione da sola ha la visione completa di un sistema che è insieme prodotto di credito, trattamento di dati e sistema AI regolato.

- **Responsabile AI.** Owner esecutivo del framework: inventario dei modelli, budget di governance, escalation. Il ruolo fallisce se ha responsabilità senza autorità: riporta all'amministratore delegato, non a una funzione tecnica.
- **Model Owner.** Una persona nominata per ciascun modello in produzione: risponde di performance, equità, documentazione e del rispetto delle condizioni d'uso. Prima linea.
- **Model Steward.** Gestisce l'esercizio del modello: monitoraggio, log, versioni, esecuzione dei processi di modifica. Prima linea, braccio operativo del Model Owner.
- **Data Owner.** Risponde delle fonti dati: qualità, provenienza, basi giuridiche insieme al DPO, attestazione di idoneità dei dataset (art. 10).
- **Validazione indipendente.** Nella funzione rischio: valida modelli e metriche prima del rilascio (G2) senza aver partecipato allo sviluppo. Indipendenza gerarchica dalla prima linea.
- **Compliance e DPO.** Seconda linea: presidio normativo (AI Act, disciplina creditizia) e protezione dati; il DPO è accountable su FRIA e DPIA.
- **Internal audit.** Terza linea: verifica periodica dell'impianto e delle evidenze, riporta al Consiglio.

5.2 Ciclo di vita del modello e gate

Il ciclo di vita è la colonna vertebrale operativa del framework: cinque gate presidiati dal Comitato, ciascuno con criteri di superamento espliciti e artefatti richiesti. G0 chiude l'intake: classificazione AI Act

documentata e iscrizione a inventario, nessun lavoro di sviluppo prima. G1 approva dati e impostazione: fonti e basi giuridiche, LIA dove serve, metrica di equità scelta e motivata per iscritto. G2 è la validazione indipendente: performance e bias misurati per segmento, robustezza su casi limite. G3 autorizza il rilascio: documentazione tecnica completa, Model Card, FRIA e DPIA aggiornate, disegno della supervisione umana, sign-off verbalizzato. G4 è ricorrente: review periodica su KPI, drift e esiti del monitoraggio post-market.

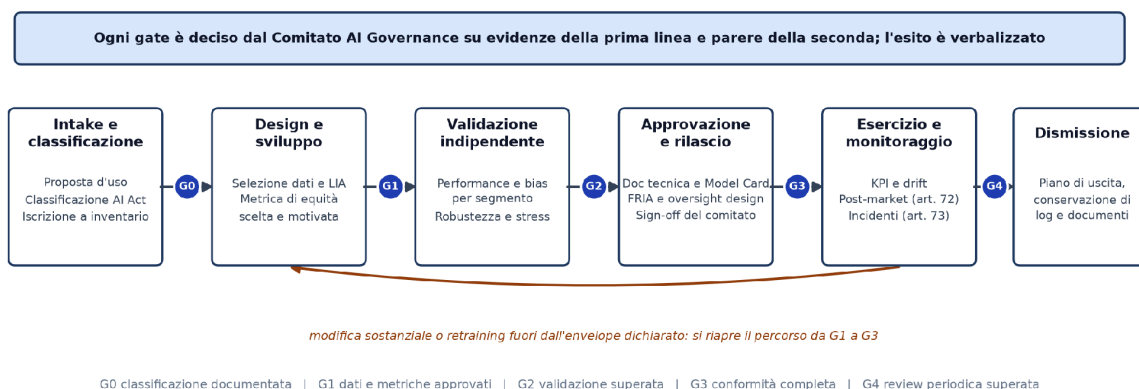


Figura 3 - Il ciclo di vita con i gate G0-G4 e il ritorno obbligato in caso di modifica sostanziale.

Il punto più delicato del ciclo è il ritorno. Un modello di scoring non è un artefatto statico: retraining periodici, nuove fonti dati, ricalibrizioni. Il framework adotta la logica dell'AI Act sulla modifica sostanziale: al G3 il Model Owner dichiara un envelope di variazione previsto (cadenza e natura dei retraining, intervalli ammessi delle metriche); ciò che resta nell'envelope è manutenzione tracciata, ciò che ne esce riapre il percorso da G1 a G3 e, sul piano regolatorio, la valutazione di conformità. Scrivere bene quell'envelope è uno degli atti a più alto valore dell'intero impianto: troppo stretto e ogni ricalibrazione diventa una pratica, troppo largo e la conformità dichiarata smette di descrivere il sistema reale.

5.3 Matrice RACI del ciclo di vita

La matrice assegna le responsabilità sulle attività del ciclo di vita. Una regola sola, applicata senza eccezioni: un unico Accountable per riga. Dove la tentazione di metterne due è più forte, ad esempio su FRIA e DPIA a cavallo tra privacy e compliance, la matrice sceglie (il DPO) e affida all'altro il ruolo di Responsible: la responsabilità condivisa è il modo più elegante di non averne nessuna.

Attività	CdA	Co m.	RAI	MO	MS	DO	VAL	CM P	DPO	AUD
Risk appetite e approvazione del framework	A	R	C	I	I	I	C	C	C	I
Intake e classificazione AI Act (G0)	I	A	R	R	I	C	I	C	C	I
Inventario dei modelli	I	A	R	R	R	I	I	I	I	I
Selezione dati, basi giuridiche, LIA		I	C	R	I	R	C	C	A	I
Scelta e motivazione delle metriche di equità		A	C	R	I	C	R	C	C	I
Sviluppo e documentazione del modello		I	C	A	R	C	I	I	I	I

Attività	CdA	Co m.	RAI	MO	MS	DO	VAL	CM P	DPO	AUD
Validazione indipendente (G2)		A	I	C	I	C	R	I	I	I
Documentazione tecnica e Model Card		I	C	A	R	C	C	C	I	I
FRIA e DPIA	I	C	C	R	I	C	I	R	A	I
Approvazione del rilascio (G3)	I	A	R	R	I	I	C	C	C	I
Monitoraggio KPI, drift, post-market (G4)	I	I	C	A	R	C	C	I	I	I
Gestione e notifica incidenti	I	C	C	R	R	I	I	A	C	I
Retraining e gestione delle modifiche		A	C	R	R	C	C	I	I	I
Audit interno del framework	I	I	I	I	I	I	I	I	I	A/R
Dismissione del modello		A	R	R	R	C	I	C	C	I

Tabella 5 - Matrice RACI sul ciclo di vita del modello.

CdA = Consiglio di amministrazione; Com. = Comitato AI Governance; RAI = Responsabile AI; MO = Model Owner; MS = Model Steward; DO = Data Owner; VAL = validazione indipendente (funzione rischio); CMP = Compliance; DPO = Data Protection Officer; AUD = Internal audit. A = Accountable (unico per riga), R = Responsible, C = Consulted, I = Informed; A/R = accountable ed esecutore (solo audit del framework).

Lettura critica. Tre scelte di disegno meritano difesa esplicita. Il Comitato, sui gate del ciclo di vita, è Accountable e mai Responsible: decide su evidenze prodotte da altri, e se producesse ciò che approva smetterebbe di essere un controllo. Il CdA compare poco e sempre come A o I di vertice: una matrice in cui il Consiglio è operativo è una matrice che non ha capito a cosa serve un Consiglio. Infine l'audit è quasi ovunque I: la terza linea che partecipa ai processi che dovrà verificare perde l'indipendenza, e la casella A/R sull'audit del framework, dove è insieme responsabile ed esecutrice, è l'unica che le spetta.

6. Mappatura dei rischi

6.1 Metodologia

La mappatura copre le dieci categorie richieste dalla traccia e per ciascuna fornisce i campi previsti: descrizione, impatti su cliente e azienda, indicatori di monitoraggio ad alto livello, severità e accountability organizzativa. Le scale sono qualitative a tre livelli, come da traccia: la probabilità (Bassa, Media, Alta) stima la plausibilità del rischio nello stato attuale dei controlli; la severità (Basso, Medio, Alto) l'impatto atteso su clienti e azienda se il rischio si materializza. La priorità combina i due assi nella matrice della figura 4 e ordina gli investimenti di controllo. Le stime poggiano su giudizio informato, non su serie storiche: è un limite accettato, coerente con lo scopo del registro, ordinare l'azione, non quantificare perdite attese.

Il registro non è un'istantanea: l'art. 9 chiede un processo iterativo, e la parola ha peso legale. Ogni rischio ha un owner e una cadenza di revisione trimestrale; il monitoraggio post-market (art. 72) e gli incidenti riaprono le valutazioni. Un risk file fermo alla data del rilascio, per un sistema in produzione da un anno, in audit risponde contro chi lo ha scritto.

6.2 Le dieci categorie di rischio

RC01 - Discriminazione e bias

Il bias entra nel credito PMI da canali noti e documentati: bias storico nelle serie di erogato (chi non ha mai ricevuto credito non produce storico positivo, e il modello impara che l'assenza di storia è rischio), sottorappresentazione di microimprese giovani e di interi settori nei dati di addestramento, proxy features che ricostruiscono caratteristiche protette del titolare effettivo a partire da CAP, codice ATECO o anzianità del conto, feedback loop per cui i richiedenti rifiutati escono dal dataset e il modello non impara mai di essersi sbagliato su di loro. Il fallimento è doppio e simmetrico: un modello troppo severo produce esclusione finanziaria, uno troppo permissivo produce sovraindebitamento, e i due errori colpiscono gli stessi segmenti deboli.

Impatti sul cliente: rifiuto o pricing peggiorativo sistematico per gruppi di titolari (genere, origine, età) o per territori, senza giustificazione oggettiva. Impatti sull'azienda: discriminazione indiretta ai sensi della normativa antidiscriminatoria, contenzioso, sanzioni, perdita di legittimità commerciale del prodotto.

Indicatori di monitoraggio: equal opportunity gap per segmento a ogni release e su base mensile; regola dei quattro quinti come soglia di screening; trend del gap nel tempo.

Valutazione: probabilità alta, severità alta, priorità critica. Probabilità alta: senza l'esame esplicito richiesto dall'art. 10, il bias nei dati creditizi è l'esito atteso, non l'eccezione. Severità alta: tocca un diritto fondamentale, la ragione per cui il credit scoring sta nell'Annex III. Owner: Model Owner (validazione di seconda linea).

RC02 - Accuratezza e affidabilità

Errore sistematico nella stima del rischio, nelle due direzioni: la sottostima genera perdite su crediti e accantonamenti insufficienti, la sovrastima genera tassi di rifiuto ingiustificati e perdita di volumi. Il punto tecnico che la governance deve fissare è che le metriche dichiarate valgono sulla distribuzione su cui sono state misurate: il drift macroeconomico (tassi, costi energetici, stagionalità settoriale) le erode in silenzio, e un claim di accuratezza senza condizioni di validità è falso il giorno dopo la misura.

Impatti sul cliente: rifiuti o condizioni errate su richieste sane; pricing non coerente col rischio effettivo. Impatti sull'azienda: perdite su crediti, accantonamenti inadeguati, perdita di credibilità verso investitori e vigilanza.

Indicatori di monitoraggio: AUC/KS e calibrazione per segmento con condizioni di validità dichiarate; PSI su input e score; confronto previsto/osservato sui default a 12 mesi.

Valutazione: probabilità media, severità alta, priorità alta. Probabilità media: il monitoraggio di performance esiste già. Severità alta: l'errore sistematico agisce su interi volumi di portafoglio, non su singole pratiche. Owner: Model Owner.

RC03 - Trasparenza e spiegabilità

Due livelli distinti che la discussione pubblica confonde: la trasparenza di sistema (il richiedente sa che uno scoring automatico contribuisce alla decisione, con quali dati e finalità) e la spiegazione della singola decisione (i motivi principali di un rifiuto o di un'offerta condizionata). Con l'art. 86 dell'AI Act e l'art. 22 GDPR la seconda è un obbligo esigibile, non una cortesia; la difficoltà pratica è tradurre l'importanza delle feature in motivi comprensibili e azionabili per un imprenditore, senza rivelare la logica al punto da renderla manipolabile.

Impatti sul cliente: impossibilità di capire e contestare un rifiuto; sfiducia verso il canale digitale. Impatti sull'azienda: reclami, rilievi delle autorità, decisioni indifendibili in sede di contenzioso.

Indicatori di monitoraggio: tasso di consegna delle spiegazioni individuali; reclami per spiegazione incomprensibile; copertura dei template di motivazione sulle causali di rifiuto.

Valutazione: probabilità alta, severità media, priorità alta. Probabilità alta: senza progettazione dedicata la lacuna è certa, è lo stato di fatto dei sistemi di scoring. Severità media: il danno passa da reclami e vigilanza più che da perdite dirette. Owner: Business credito.

RC04 - Protezione dei dati e privacy

Il modello combina dati transazionali, contabili, comportamento digitale e dati alternativi: la superficie GDPR è ampia, e resta personale anche quando il cliente è una società, perché titolari effettivi e garanti sono persone fisiche. I punti critici: base giuridica distinta per categoria di dato (per il legittimo interesse serve una LIA documentata e viva), minimizzazione dei dati alternativi (il valore predittivo marginale va pesato contro l'intrusività, non presunto), retention degli snapshot di training, possibilità che il modello inferisca attributi sensibili da dati ordinari.

Impatti sul cliente: trattamenti oltre le aspettative ragionevoli; profilazione opaca dei comportamenti digitali. Impatti sull'azienda: sanzioni e ordini del Garante; contaminazione dei modelli addestrati su basi illecite, che il parere EDPB 28/2024 rende un rischio concreto anche a valle.

Indicatori di monitoraggio: copertura LIA per fonte dato; richieste degli interessati evase nei termini; età degli snapshot di training rispetto alla policy di retention.

Valutazione: probabilità media, severità alta, priorità alta. Probabilità media: DPIA e pratiche di protezione dati esistono già in azienda. Severità alta: scala del trattamento e sensibilità delle inferenze possibili. Owner: DPO.

RC05 - Robustezza e resilienza operativa

Tre fenomeni distinti sotto la stessa etichetta: il degrado silenzioso nel tempo (drift di popolazione e di relazione tra variabili ed esito), il comportamento indefinito su input fuori distribuzione (settori nuovi, dati mancanti, casi limite), la manipolazione degli input da parte dei richiedenti, dove i dati comportamentali e alternativi sono i più esposti: preparare il conto corrente nei mesi che precedono la richiesta è gaming a costo quasi nullo. La regola di governance è avere un fallback definito: quando il modello non è affidabile si instrada a istruttoria manuale, non si estrapola con fiducia.

Impatti sul cliente: esiti incoerenti tra richieste simili; decisioni fragili su profili atipici. Impatti sull'azienda: degrado della qualità del portafoglio prima che il monitoraggio standard lo intercetti.

Indicatori di monitoraggio: PSI mensile su input e score; quota di richieste instradate al fallback; esiti dei test di stress su scenari di drift.

Valutazione: probabilità media, severità media, priorità media. Probabilità e severità medie: fenomeni noti, osservabili, con contromisure di processo mature nel credito; il rischio residuo sta nella velocità di reazione. Owner: Model Steward.

RC06 - Sicurezza informatica e integrità dei dati

La superficie AI-specifica sopra la sicurezza classica: poisoning della pipeline dati (più realistico a monte, attraverso i fornitori di dati, che sui sistemi interni), manomissione degli artefatti nel model registry, estrazione del modello attraverso le API esposte ai partner, membership inference sui dati di training. L'ancoraggio normativo è doppio: art. 15 AI Act (cybersecurity del sistema come requisito di conformità, con evidenze) e DORA (modello e pipeline come asset ICT critici, con requisiti di resilienza e notifica incidenti).

Impatti sul cliente: decisioni alterate da dati manipolati; esposizione di dati personali e aziendali. Impatti sull'azienda: perdita di integrità del processo decisionale; obblighi di notifica multipli; danno reputazionale verso partner bancari.

Indicatori di monitoraggio: esiti dei controlli di integrità su dataset e artefatti; anomalie sulle query API di scoring; copertura dei test di sicurezza ML nel piano DORA.

Valutazione: probabilità bassa, severità alta, priorità media. Probabilità bassa: servono accesso o capacità mirate, e la 27001 è già operativa. Severità alta: l'integrità della decisione è il prodotto stesso. Owner: Sicurezza ICT (con Model Steward).

RC07 - Governance e accountability

Il rischio che questo framework esista per chiudere: decisioni sul modello senza un responsabile nominato, modifiche non tracciate, modelli ombra fuori inventario, organi consultivi senza autorità di veto. La simulazione del capitolo 7 mostra che è il rischio più concreto dello stato attuale: la capacità tecnica c'è, la responsabilità documentata no. È anche il rischio più subdolo, perché non produce eventi avversi propri: amplifica il costo e la durata di tutti gli altri.

Impatti sul cliente: nessun interlocutore responsabile per esiti contestati; tempi di risposta lunghi sui reclami. Impatti sull'azienda: indifendibilità in audit e ispezione; art. 17 scoperto; documentazione retrofittata riconoscibile come tale.

Indicatori di monitoraggio: copertura dell'inventario modelli; quota di modifiche con approvazione tracciata; il test di funzionamento del cap. 4: un rilascio fermato da un gate almeno una volta.

Valutazione: probabilità alta, severità media, priorità alta. Probabilità alta: senza intervento, la lacuna organizzativa è lo stato di fatto. Severità media: non genera danni diretti, ma moltiplica quelli degli altri rischi. Owner: Comitato AI Governance.

RC08 - Rischio contrattuale e fornitori terzi

Le dipendenze della filiera: fornitori di dati (credit bureau, open banking, dati alternativi), cloud provider, componenti e librerie ML. Tre esposizioni distinte: la qualità e la liceità del dato acquistato (la base giuridica del fornitore non si eredita automaticamente), la continuità del servizio (revoca o degrado di una API dati), la catena di evidenze art. 10 su dati che CrediPulse non controlla alla fonte. L'art. 25 AI Act aggiunge la trappola di ruolo: modificare sostanzialmente o ri-brandizzare un componente di terzi significa assumerne gli obblighi da provider. DORA impone il registro delle terze parti ICT critiche e clausole contrattuali minime.

Impatti sul cliente: decisioni basate su dati di terzi errati o non aggiornati, difficili da contestare. Impatti sull'azienda: interruzioni operative; evidenze di conformità incomplete sulla parte di filiera non controllata.

Indicatori di monitoraggio: copertura delle clausole chiave (audit, notifica incidenti, qualità dati) sui fornitori critici; esiti della due diligence periodica; test di continuità sulle fonti dato.

Valutazione: probabilità media, severità media, priorità media. Probabilità e severità medie: filiera contenuta e contrattualizzabile, ma il controllo effettivo sui dati di terzi resta strutturalmente limitato. Owner: Compliance (con Procurement).

RC09 - Rischio sistemico e di mercato

I rischi aggregati che nessuna singola pratica rivela: concentrazione di portafoglio indotta dal modello (il modello compra sistematicamente lo stesso profilo di rischio), prociclicità (in recessione lo score peggiora per interi settori e la stretta creditizia automatica amplifica il ciclo), monocultura di modello nel mercato PMI (operatori diversi, errori correlati). Sfugge per natura alle checklist di conformità sul singolo sistema: si governa con risk appetite, limiti di portafoglio e quote di decisione umana, non con requisiti tecnici.

Impatti sul cliente: effetto aggregato: intere categorie di imprese razionate negli stessi mesi da più operatori. Impatti sull'azienda: concentrazione e perdite correlate; attenzione della vigilanza prudenziale sugli effetti aggregati dello scoring.

Indicatori di monitoraggio: indici di concentrazione settoriale e geografica rispetto ai limiti; sensitivity dello score a scenari macro; quota di decisioni interamente automatiche per fascia di importo.

Valutazione: probabilità bassa, severità alta, priorità media. Probabilità bassa sull'orizzonte di piano. Severità alta: tocca la stabilità del portafoglio ed è il terreno dove la vigilanza finanziaria e l'AI Act si incontrano. Owner: CRO.

RC10 - Rischio normativo e di compliance

La non conformità come rischio in sé: gli obblighi high-risk dell'AI Act si applicano dal 2026-08-02 e la simulazione del capitolo 7 mostra gap aperti su documentazione, logging e valutazione di conformità. Si aggiungono la misclassificazione (per questo sistema l'art. 6(3) non è invocabile, essendoci profilazione: sostenere il contrario sarebbe una violazione autonoma), l'evoluzione del quadro (norme armonizzate in ritardo, guidance in arrivo) e l'intreccio con la disciplina creditizia e GDPR. Le sanzioni per violazione degli obblighi arrivano a 15 milioni di euro o al 3% del fatturato mondiale, se maggiore (art. 99; per le PMI vale il minore dei due), ma il costo maggiore sarebbe l'ordine di ritiro del sistema dal mercato.

Impatti sul cliente: continuità del servizio a rischio se il sistema viene limitato o ritirato. Impatti sull'azienda: sanzioni, ritiro o sospensione del sistema, esclusione da partnership bancarie che richiedono conformità dimostrabile.

Indicatori di monitoraggio: gap aperti per articolo con owner e scadenza; tempo medio di chiusura; presidio nominato sugli aggiornamenti normativi con log delle valutazioni di impatto.

Valutazione: probabilità media, severità alta, priorità alta. Probabilità media: il percorso è avviato ma la finestra è stretta. Severità alta: le conseguenze includono il blocco del sistema, non solo la sanzione. Owner: Compliance.

6.3 Vista d'insieme e priorità

ID	Categoria di rischio	Probabilità	Severità	Priorità	Owner
RC01	Discriminazione e bias	Alta	Alto	Critica	Model Owner
RC02	Accuratezza e affidabilità	Media	Alto	Alta	Model Owner
RC03	Trasparenza e spiegabilità	Alta	Medio	Alta	Business credito
RC04	Protezione dei dati e privacy	Media	Alto	Alta	DPO
RC07	Governance e accountability	Alta	Medio	Alta	Comitato AI Governance
RC10	Rischio normativo e di compliance	Media	Alto	Alta	Compliance

ID	Categoria di rischio	Probabilità	Severità	Priorità	Owner
RC05	Robustezza e resilienza operativa	Media	Medio	Media	Model Steward
RC06	Sicurezza informatica e integrità dei dati	Bassa	Alto	Media	Sicurezza ICT
RC08	Rischio contrattuale e fornitori terzi	Media	Medio	Media	Compliance
RC09	Rischio sistemico e di mercato	Bassa	Alto	Media	CRO

Tabella 6 - Registro dei rischi del modello CS-PMI, ordinato per priorità.



Figura 4 - Heatmap probabilità per severità con le dieci categorie posizionate.

Lettura critica. la distribuzione dice tre cose. Primo: l'unico rischio critico è quello di equità (RC01), non un rischio tecnico; è coerente con la natura del sistema, che sta nell'Annex III proprio per il suo potenziale discriminatorio, e giustifica la scelta di mettere la metrica di fairness tra i criteri di gate anziché tra le buone intenzioni. Secondo: il cluster ad alta priorità mescola rischi da modello (RC02, RC04) e rischi da organizzazione (RC03, RC07, RC10); i secondi si chiudono con processo e disciplina prima che con tecnica, e sono i più rapidi da abbattere, come la roadmap del capitolo 10 riflette. Terzo: RC09 è l'osservato speciale, probabilità bassa ma il registro va riletto a ogni cambio di ciclo economico; è il rischio la cui probabilità cambia per cause che nessun controllo interno governa. Un'ultima nota sulla scala: nessuna

categoria ricade oggi su severità bassa, e per un sistema che decide del credito altrui è l'esito atteso, non un vizio di calibrazione della scala.

7. Simulazione di analisi di conformità (AI Act)

7.1 Metodo e stato di partenza ipotizzato

La simulazione percorre gli obblighi applicabili al sistema CS-PMI e valuta lo stato su tre valori: presidiato, parziale, gap. Ogni gap ha un owner (sigle della RACI o funzione nominata) e un orizzonte di chiusura ripreso dalla roadmap. Perché l'esercizio sia onesto, lo stato di partenza va dichiarato: CrediPulse è ipotizzata come una scale-up con pratiche tecniche solide e governance documentale in ritardo, il profilo più comune nel fintech. In concreto: model risk management del credito operativo ma non formalizzato in ottica AI Act, certificazione ISO/IEC 27001, processi DORA in corso di adozione, DPIA del 2024 da aggiornare, documentazione del modello frammentata tra wiki e repository, logging applicativo presente ma non decisionale, nessuna FRIA.

Il vero prodotto della conformità

Per il credit scoring la valutazione di conformità passa dal controllo interno (Annex VI): nessun ente terzo certifica, l'azienda si autovaluta e ne risponde. L'autovalutazione non abbassa l'asticella, la alza: senza il timbro di un notified body, ciò che difende l'azienda in ispezione è la qualità del fascicolo. Evidenze puntuali contro affermazioni, documenti vivi con storia di versioni contro istantanee, coerenza incrociata tra risk file, report di test e schede dati. La conformità retrofittata si riconosce dai timestamp identici; gli auditor la cercano per prima.

7.2 Obblighi da provider

Requisito	Stato	Gap e azione	Owner	Orizzonte
Sistema di gestione del rischio (art. 9)	Parziale	Il model risk management del credito copre il ciclo tecnico; manca l'iteratività documentata su misuse prevedibile e gruppi vulnerabili. Estendere il processo esistente, non duplicarlo	MO	0-3 mesi
Dati e data governance, esame dei bias (art. 10)	Parziale	Provenienza e qualità dei dati tracciate; l'esame documentato dei bias con esiti e decisioni non è sistematico. L'art. 10(5) abilita il trattamento di categorie particolari per la correzione dei bias, con garanzie	DO	0-3 mesi
Documentazione tecnica (art. 11, Annex IV)	Gap	Documentazione frammentata tra wiki e repository; il fascicolo conforme all'Annex IV va composto, mantenuto versionato e conservato dieci anni (art. 18)	MO	0-3 mesi
Registrazione automatica dei log (artt. 12, 19)	Parziale	Log applicativi presenti; il logging delle inference (input, versione modello, score, esito, override) non copre l'intera catena decisionale. Requisito di prodotto, primo orizzonte	MS	0-3 mesi
Istruzioni d'uso interne (art. 13)	Parziale	CrediPulse è anche deployer di sé stessa: il documento d'uso formalizzato (capacità, limiti, condizioni di validità, misure di oversight) serve comunque, ed è l'input della supervisione umana	MO	3-6 mesi
Sorveglianza umana (art. 14)	Parziale	La fascia grigia con revisione dell'analista esiste; mancano formalizzazione dell'autorità di override, formazione contro l'automation bias e misura dell'override rate	Com.	3-6 mesi

Requisito	Stato	Gap e azione	Owner	Orizzonte
Accuratezza, robustezza, cybersecurity (art. 15)	Parziale	Metriche di accuratezza monitorate; robustezza su out-of-distribution e test adversarial non sistematici; evidenze di sicurezza ML da raccordare al piano DORA	MO	3-6 mesi
Sistema di gestione qualità (art. 17)	Gap	Da costruire integrando ISO/IEC 27001 esistente e processi del credito, con ISO/IEC 42001 come struttura; l'appoggio alla governance settoriale (art. 17(4)) non copre artt. 9, 72 e 73, trattati come voci separate	CMP	3-6 mesi
Valutazione di conformità e marcatura (artt. 43, 47, 48)	Gap	Percorso di controllo interno (Annex VI) da pianificare e documentare; senza norme armonizzate applicabili, ogni requisito va argomentato da principi	CMP	3-6 mesi
Registrazione nella banca dati UE (art. 49)	Gap	Adempimento puntuale, da eseguire prima dell'immissione sul mercato nel regime applicabile	CMP	3-6 mesi
Monitoraggio post-market (art. 72)	Parziale	Il monitoraggio tecnico esiste; manca il piano formale che raccoglie l'esperienza d'uso e la riversa nel ciclo art. 9	MS	3-6 mesi
Segnalazione incidenti gravi (art. 73)	Gap	Il processo incidenti ICT (DORA) esiste; il canale AI Act con definizioni, soglie e termini (15 giorni; 10 in caso di decesso; 2 per violazione estesa o incidente su infrastrutture critiche) va innestato sullo stesso intake	CMP	0-3 mesi
Azioni correttive e dovere di informazione (art. 20)	Gap	Procedura di messa in conformità, ritiro o richiamo del sistema con informazione ad autorità e soggetti della catena; distinta dalla segnalazione ex art. 73, da innestare sullo stesso processo	CMP	3-6 mesi
Alfabetizzazione AI del personale (art. 4)	Parziale	Obbligo già applicabile dal 2025-02-02: formazione per ruolo (analisti, sviluppo, organi) da strutturare con registri	RAI	3-6 mesi

Tabella 7 - Checklist di conformità lato provider.

7.3 Obblighi da deployer e tutele verso i richiedenti

Requisito	Stato	Gap e azione	Owner	Orizzonte
Uso conforme alle istruzioni e monitoraggio (art. 26)	Parziale	L'esercizio segue prassi consolidate ma non è ancorato a istruzioni d'uso formalizzate (art. 13); i log di esercizio vanno conservati secondo l'art. 26(6)	MS	3-6 mesi
FRIA prima della messa in servizio (art. 27)	Gap	Obbligatoria per il credit scoring (Annex III 5(b)): da eseguire con il template dell'appendice D, riusando la DPIA dove sovrapponibile (art. 27(4)), e da notificare all'autorità di vigilanza	DPO	0-3 mesi
Salvaguardie art. 22 GDPR sulla decisione automatizzata	Parziale	L'intervento umano in fascia grigia esiste; il diritto a ottenere l'intervento, esprimere opinione e contestare va reso esercitabile per ogni esito, non solo per i casi dubbi	DPO	0-3 mesi
Spiegazione della singola decisione (art. 86)	Gap	Il diritto alla spiegazione per decisioni basate su sistemi Annex III richiede motivazioni individuali comprensibili: template e processo da progettare col business	Business credito	3-6 mesi

Requisito	Stato	Gap e azione	Owner	Orizzonte
Informazione ai richiedenti dell'uso del sistema (art. 26(11))	Parziale	L'art. 26(11) obbliga a informare le persone fisiche di essere soggette all'uso di un sistema ad alto rischio: l'informativa privacy cita la profilazione, la disclosure AI Act esplicita va inserita nel funnel di richiesta	DPO	0-3 mesi

Tabella 8 - Checklist di conformità lato deployer.

Lettura critica. Letta per righe la gap analysis è lunga; letta per colonne converge su due assi. Il primo è documentale: fascicolo tecnico, QMS, istruzioni d'uso e FRIA sono facce dello stesso lavoro di formalizzazione di pratiche che in parte esistono già; è lavoro di scrittura disciplinata, non di ricostruzione, e la roadmap lo concentra nel primo orizzonte. Il secondo è la tracciabilità decisionale, che serve insieme l'art. 12, la difendibilità delle spiegazioni ex art. 86, la forensics DORA e la dimostrabilità GDPR: è il singolo investimento con il rendimento di conformità più alto dell'intero piano. Vale anche una lettura di segno opposto: nessun gap richiede di toccare il modello. La distanza dalla conformità è organizzativa, non tecnica, il che è una buona notizia con una data di scadenza.

8. Documentazione di accountability

8.1 L'architettura documentale

La documentazione di un sistema ad alto rischio non è una pila di file, è una catena con versi di percorrenza: le evidenze operative alimentano il fascicolo tecnico e i documenti di accountability, e questi sostengono la valutazione di conformità, la dichiarazione UE, la marcatura e la registrazione. La figura 5 la disegna con gli owner; la proprietà di ogni documento è nella RACI, e la coerenza incrociata tra i livelli, il risk file che cita il report di validazione che cita la scheda dati, è ciò che un auditor verifica per primo.

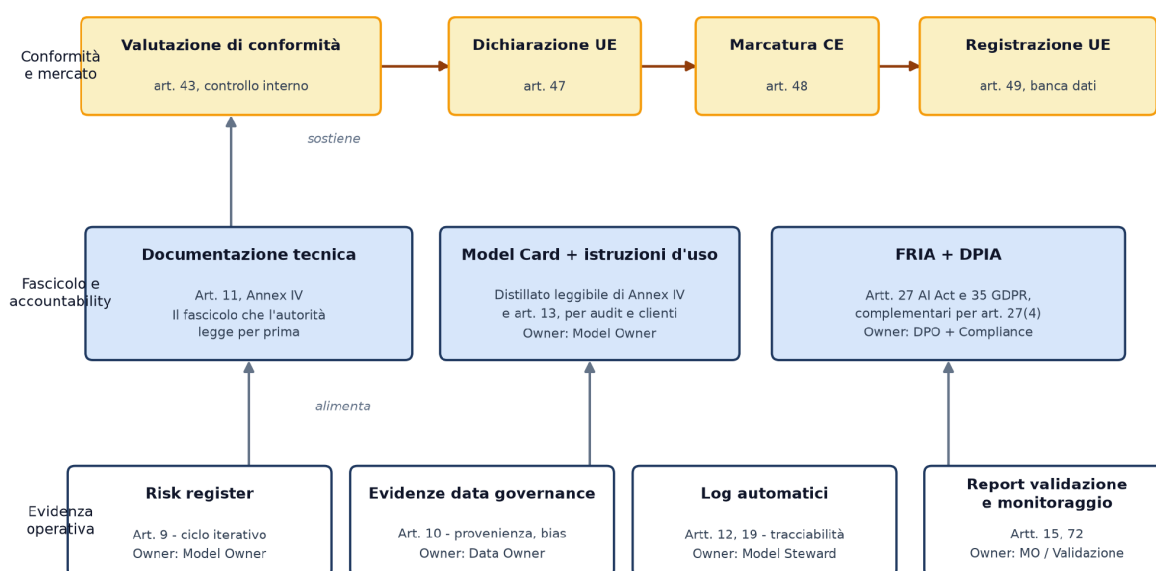


Figura 5 - L'architettura documentale: evidenze operative, fascicolo e accountability, catena di conformità.

Una precisazione terminologica dovuta: Model Card non è un termine dell'AI Act. È lo strumento, nato nella letteratura tecnica, con cui questo framework rende leggibili i contenuti che l'Annex IV e l'art. 13

richiedono: un distillato per auditor, partner e funzioni interne che non leggeranno mai un fascicolo tecnico di duecento pagine, con l'identità del modello, l'uso previsto e vietato, i dati, le metriche con condizioni di validità, le valutazioni di equità, i limiti noti, i requisiti di supervisione. Non sostituisce il fascicolo: lo rappresenta, e ogni sua versione punta alla versione del fascicolo da cui deriva.

8.2 Model Card: uso e ciclo di aggiornamento

Il template completo è nell'appendice C; l'istanza compilata per CS-PMI nell'appendice E. Le regole d'uso sono tre. La Model Card nasce al G3 e senza di essa il rilascio non passa. Si aggiorna a ogni nuova versione del modello e a ogni revisione G4 che cambi metriche, limiti o condizioni d'uso; una card più vecchia dell'ultimo retraining è un finding, non un dettaglio. La firma il Model Owner: il documento che descrive il modello e la persona che ne risponde coincidono per costruzione.

8.3 FRIA: processo e criterio di qualità

La valutazione d'impatto sui diritti fondamentali (art. 27) è l'obbligo deployer che il credit scoring non può evitare: la valutazione del merito creditizio è tra i casi espressamente indicati. Il processo del framework: la FRIA si conduce prima della messa in servizio e si rivede quando cambiano uso, popolazione interessata o esiti del monitoraggio; riusa la DPIA dove i perimetri si sovrappongono (art. 27(4)) ed estende l'analisi dai dati ai diritti, non discriminazione, protezione dei dati, tutela effettiva contro le decisioni; l'esito si notifica all'autorità di vigilanza del mercato. Owner è il DPO, con Compliance responsible e il business consultato; il template è nell'appendice D, l'istanza compilata nell'appendice F.

Il criterio di qualità che il framework adotta è la falsificabilità: una FRIA che non avrebbe mai potuto concludere 'non mettere in servizio' non è una valutazione, è un modulo con una riga per la firma. L'istanza dell'appendice F prende il criterio sul serio: si chiude con un via libera condizionato a misure con owner e scadenza, e dichiara quali evidenze future riaprirebbero il giudizio.

9. Monitoraggio, indicatori e incidenti

Il monitoraggio trasforma i principi del capitolo 4 in numeri con soglie e conseguenze. Pochi indicatori, ciascuno con owner, cadenza e una regola di escalation scritta: un cruscotto di quaranta metriche senza soglie è assicurazione, non controllo.

Indicatore	Cadenza	Soglia e conseguenza	Owner
Equal opportunity gap per segmento	Mensile	Oltre 0.05 su un segmento: escalation al Comitato, revisione del modello in G4 anticipato	Model Owner
Override rate della revisione umana	Mensile	Banda attesa 5-15%: sotto, la supervisione è un timbro; sopra, il modello non è affidabile. Entrambi sono finding	Business credito
Consegna delle spiegazioni individuali	Mensile	100% dei rifiuti e delle offerte condizionate; reclami per opacità in tendenza calante	Business credito
PSI su input e score	Mensile	Oltre 0.2: revisione; oltre 0.25: G4 anticipato e valutazione dell'envelope	Model Steward
Copertura del logging decisionale	Continua	100%; ogni scostamento è trattato come incidente, non come degrado	Model Steward
Richieste art. 22 / art. 86 evase nei termini	Mensile	100% entro il termine interno di 15 giorni	DPO

Indicatore	Cadenza	Soglia e conseguenza	Owner
Tempo di presa in carico degli incidenti	Per evento	Mediana sotto le 72 ore dalla prima evidenza; trend in discesa	Compliance

Tabella 9 - Indicatori del framework con soglie ed escalation.

Il monitoraggio post-market (art. 72) chiude il cerchio con l'art. 9: l'esperienza d'uso reale, drift, override, reclami, esiti dei crediti, rientra nel registro dei rischi e può riaprire le valutazioni fatte al rilascio. Sugli incidenti, il punto organizzativo decisivo è che un solo evento può accendere più orologi insieme: un incidente grave ex art. 73 AI Act (15 giorni; 10 in caso di decesso; 2 per violazione estesa o incidente su infrastrutture critiche), una violazione di dati personali ex artt. 33-34 GDPR (72 ore al Garante), un incidente ICT grave sotto DORA con il suo ciclo di notifiche iniziale, intermedia e finale. Tre definizioni, tre destinatari, tre termini: l'unico disegno che regge è un intake unico che classifica l'evento contro tutti i regimi e instrada le notifiche in parallelo. Il parametro controllabile non è il termine, che è legge, ma il tempo di presa di coscienza: si riduce con il logging e con esercitazioni periodiche, non con la fortuna.

Le cadenze di revisione chiudono il sistema: registro dei rischi trimestrale, framework annuale (o a ogni cambio normativo o di prodotto rilevante), reporting al Consiglio trimestrale con gli indicatori della tabella 9 e lo stato dei gap del capitolo 7.

10. Roadmap di adozione e criteri di successo

La roadmap ordina la chiusura dei gap su tre orizzonti, con un criterio dichiarato: prima ciò che è bloccante per legge o abilitante per tutto il resto (classificazione formale, FRIA, logging, fascicolo tecnico), poi ciò che consolida (QMS, formazione, robustezza), infine ciò che matura (certificazione, audit indipendente). Gli owner sono quelli delle checklist del capitolo 7.

Orizzonte	Attività principali	Aggancio
0-3 mesi	Delibera del Consiglio su framework e risk appetite; classificazione formale e inventario (G0 retroattivo sul modello in produzione); FRIA con notifica e aggiornamento DPIA; piano di logging decisionale come requisito di prodotto; composizione del fascicolo tecnico; canale incidenti AI Act sull'intake esistente; salvaguardie art. 22 esplicitate nel funnel	Gap '0-3' delle tabelle 7-8; artt. 6, 9-12, 19, 26(11), 27, 73
3-6 mesi	QMS art. 17 integrato su 27001 e processi del credito (struttura ISO/IEC 42001); istruzioni d'uso interne; formalizzazione della supervisione umana con formazione anti automation bias; template di spiegazione art. 86; valutazione di conformità (Annex VI) e registrazione UE; programma di alfabetizzazione AI con registri	Gap '3-6' delle tabelle 7-8; artt. 4, 13-15, 17, 20, 26, 43, 47-49, 72, 86
6-12 mesi	Test di robustezza e adversarial sistematici nel piano DORA; audit di terza linea sull'intero impianto; valutazione della certificazione ISO/IEC 42001; revisione annuale del framework con esiti del primo ciclo di KPI	Consolidamento e messa a regime dell'intero impianto

Tabella 10 - Roadmap su tre orizzonti.

I criteri di successo della traccia trovano ciascuno una verifica concreta:

Criterio di successo	Dove	Evidenza attesa
Framework approvato dal Board con ruoli e processi	Capp. 4-5	Delibera del CdA e verbale; RACI adottata
Template Model Card e FRIA pronti all'uso	App. C-D	Template versionati; istanze compilate (E-F) come prova d'uso
Simulazione di compliance con gap e owner	Cap. 7	Tabelle 7-8 con stato, owner, orizzonte; riesame trimestrale
Capacità di dimostrare lo sforzo di conformità	Capp. 7-9	Corpus unico di evidenze; fascicolo tecnico vivo; KPI con storia
Chiarezza di responsabilità e punti di controllo	Capp. 5, 9	RACI, gate verbalizzati, escalation esercitate almeno una volta

Tabella 11 - Criteri di successo e loro verifica.

11. Limiti del framework e follow-up

Quattro limiti vanno dichiarati. Il framework è di alto livello per mandato: fissa requisiti, responsabilità e punti di controllo, non implementazioni; la distanza tra un principio e la sua esecuzione tecnica resta lavoro a valle, e nessun documento la elimina. La simulazione di conformità valuta uno stato ipotizzato, dichiarato nel capitolo 7.1: su un'azienda reale gli stati cambierebbero, il metodo no. Le soglie degli indicatori (il gap di equità a 0.05, la banda di override, i PSI) sono punti di partenza motivati dalla pratica, da tarare sui dati reali nel primo ciclo di esercizio: vanno lette come impegni iniziali espliciti, non come costanti. Infine il quadro normativo è in movimento, con le norme armonizzate in ritardo sul calendario e la guidance sull'art. 27 in evoluzione: il presidio degli aggiornamenti (RC10) esiste esattamente per questo. Questo documento non costituisce parere legale.

I follow-up naturali, in ordine: la delibera consiliare con l'adozione della RACI; l'esecuzione reale di FRIA e classificazione formale sul modello in produzione; il primo ciclo trimestrale completo di KPI e registro; a valle, l'audit di terza linea che sottoponga l'impianto alla sola verifica che conta, quella empirica: prima i processi, poi la carta che li descrive.

Appendice A - Template RACI e matrice dei ruoli

Struttura riusabile della matrice adottata nel capitolo 5, con le regole di compilazione. Le righe sono le attività del ciclo di vita del modello, le colonne i ruoli; ogni cella vale A, R, C, I o resta vuota.

Regola di compilazione	Perché
Un solo Accountable per riga, sempre	La responsabilità condivisa non è esercitabile né verificabile: due A equivalgono a zero
Ogni riga ha almeno un Responsible	Un'attività senza esecutore nominato non accade
A e R coincidono solo in prima linea, con l'eccezione dichiarata dell'audit del framework (A/R alla terza linea)	Gli organi di controllo che eseguono ciò che approvano smettono di essere controlli
La terza linea resta I su tutto tranne l'audit	Partecipare ai processi da verificare compromette l'indipendenza
La matrice si rivede a ogni modifica organizzativa	Una RACI con ruoli che non esistono più è peggio di nessuna RACI

Tabella A.1 - Regole di compilazione della matrice.

Ruolo	Missione nel framework	Linea
Consiglio di amministrazione	Approva framework e risk appetite; riceve il reporting	Vertice
Comitato AI Governance	Decide i gate G0-G4 con veto verbalizzato	Organo di governo
Responsabile AI	Owner esecutivo del framework e dell'inventario	Prima
Model Owner	Risponde del singolo modello: performance, equità, doc	Prima
Model Steward	Esercizio: monitoraggio, log, versioni, modifiche	Prima
Data Owner	Fonti dati: qualità, provenienza, idoneità (art. 10)	Prima
Validazione indipendente	Valida modelli e metriche al G2 senza averli sviluppati	Seconda
Compliance	Presidio normativo; incidenti; valutazione di conformità	Seconda
DPO	Protezione dati; accountable su FRIA e DPIA	Seconda
Internal audit	Assurance indipendente sull'impianto; riporta al CdA	Terza

Tabella A.2 - Matrice dei ruoli.

Appendice B - Template del Risk Register

Struttura del registro istanziato nel capitolo 6. Il campo evidenze è quello che trasforma il registro da opinione a fascicolo: ogni valutazione punta ai documenti che la sostengono.

Campo	Contenuto atteso	Esempio (da RC01)
ID	Identificativo stabile	RC01
Categoria	Una delle dieci categorie del framework	Discriminazione e bias
Descrizione	Meccanismo del rischio nel contesto d'uso	Proxy discrimination via CAP e settore; feedback loop sui rifiutati
Impatti	Su cliente e su azienda, distinti	Rifiuti sistematici per gruppi; contenzioso e sanzioni
Probabilità	Bassa / Media / Alta, con motivazione	Alta: senza esame art. 10 il bias è l'esito atteso
Severità	Basso / Medio / Alto (impatto atteso)	Alto: diritto fondamentale, ragione dell'Annex III
Priorità	Dalla matrice probabilità per severità	Critica
Indicatori	Metriche di monitoraggio con soglie	Equal opportunity gap mensile per segmento, soglia 0.05
Controlli collegati	Gate, policy, misure che lo trattano	G1-G2 (metrica motivata), monitoraggio disaggregato
Evidenze	Link a report, test, log, verbali che provano valutazione e trattamento	Report validazione v3.2; esame bias 2026-06; verbale G3
Owner	Ruolo che ne risponde	Model Owner
Stato e revisione	Aperto / mitigato / accettato; data ultima e prossima revisione	Mitigato; 2026-07, riesame 2026-10

Tabella B.1 - Template del Risk Register con campo evidenze.

Appendice C - Template della Model Card

Le sezioni richieste, con le note di compilazione. La card si genera al G3, si aggiorna a ogni versione e a ogni G4 con esito di modifica, ed è firmata dal Model Owner.

Sezione	Contenuto atteso	Note di compilazione
Identificazione	Nome, versione, data, ID interno, stato	L'ID punta all'inventario; una card per versione
Scopo e uso previsto	Uso autorizzato, contesti e usi vietati	Gli usi vietati sono la parte che invecchia peggio: rivederli a ogni G4
Proprietari e contatti	Model Owner, Model Steward, Data Owner	Ruoli e persone, non solo caselle funzionali
Dati	Fonti, finestra temporale, dimensioni, esclusioni, retention	Ad alto livello; il dettaglio sta nelle schede dati del fascicolo

Sezione	Contenuto atteso	Note di compilazione
Metriche di performance	Indicatori con valore, ambito e condizioni di validità	Sempre per segmento; una metrica senza condizioni è pubblicità
Valutazioni di equità	Metrica scelta e perché, esiti, aree di attenzione	La motivazione della scelta è obbligatoria: è un atto normativo, non tecnico
Limitazioni note	Dove il modello degrada o non va usato	Scritte per chi decide, non per chi sviluppa
Monitoraggio e revisioni	Indicatori attivi, cadenze, soglie	Coerenti con la tabella 9 del framework
Supervisione umana	Chi rivede, con che autorità, su quali casi	Descrivere il potere reale di override, non la presenza di un umano
Note di compliance	Classificazione AI Act, riferimenti a fascicolo, FRIA, registrazione	Puntatori versionati, non copie
Registro delle versioni	Storia delle modifiche con date e motivi	Il changelog è evidenza art. 9, non cortesia

Tabella C.1 - Template della Model Card.

Appendice D - Template della FRIA

Struttura della valutazione d'impatto sui diritti fondamentali (art. 27), coordinata con la DPIA ex art. 27(4). Owner: DPO; esito notificato all'autorità di vigilanza del mercato.

Sezione	Contenuto atteso
Intestazione	Sistema, versione, deployer, processo aziendale, data, valutatore, esito (via libera / condizionato / negativo)
Contesto e descrizione	A cosa serve il sistema, in quale processo opera, periodo e frequenza d'uso previsti
Attori e soggetti interessati	Chi lo usa, chi decide, chi subisce gli effetti; categorie di persone fisiche interessate e gruppi vulnerabili
Diritti potenzialmente impattati	Per ciascun diritto: meccanismo dell'impatto, probabilità e gravità con motivazione, tenendo conto delle informazioni del provider ex art. 13
Riuso della DPIA	Quali analisi della DPIA restano valide e cosa la FRIA aggiunge (art. 27(4))
Sorveglianza umana (art. 27(1)(e))	Come sono attuate le misure di sorveglianza umana secondo le istruzioni d'uso (art. 13): chi rivede, con quali informazioni e quale autorità di override
Misure organizzative	Policy, governance, supervisione, canali di reclamo a tutela dei diritti; rimandi ai controlli del framework
Gap identificati	Cosa manca a livello di conformità e responsabilità, con owner
Conclusioni e raccomandazioni	Esito motivato; condizioni che riaprono la valutazione; raccomandazioni di governance (non tecniche)

Sezione	Contenuto atteso
Follow-up	Azioni correttive con owner e scadenza; esito della notifica all'autorità; data di revisione

Tabella D.1 - Template della FRIA.

Appendice E - Model Card compilata: CS-PMI v3.2

Istanza d'uso del template C sul modello di scoring del caso primario. I valori sono simulati ma realistici; la struttura è quella che andrebbe in produzione.

Campo	Valore
Nome e ID	CS-PMI (Credit Score PMI) - inventario MDL-2024-003
Versione / data	3.2 - rilasciata il 2026-06-15
Stato	In produzione, canale digitale
Model Owner	Responsabile modelli di rischio (prima linea, funzione credito)
Model Steward	Team MLOps piattaforma
Data Owner	Responsabile dati di credito
Contatti	Caselle funzionali interne model-risk@, mlops@ e data-office@ sul dominio aziendale; escalation via Comitato AI Governance

Tabella E.1 - Identificazione, proprietari e contatti.

Scopo e uso previsto

Valutazione del merito creditizio di PMI e microimprese italiane per richieste di finanziamento tra 10.000 e 250.000 euro sul canale digitale. Output: classe di rischio (1-9), probabilità di default calibrata a 12 mesi, raccomandazione operativa (approvazione, rifiuto, offerta condizionata). La raccomandazione supporta la decisione; nelle classi intermedie la decisione è dell'analista. Usi vietati: credito al consumo a persone fisiche, valutazione di dipendenti o collaboratori, finalità di marketing, riuso dello score fuori dal processo di credito, mercati non italiani senza rivalidazione completa.

Dati

Quattro fonti: transazionale open banking (finestra 24 mesi), bilanci depositati (tre esercizi), comportamento nel funnel digitale, segnali pubblici sull'impresa. Training su circa 48.000 pratiche 2019-2025 con esito osservato; esclusi i settori a normativa speciale. Retention degli snapshot di training: 24 mesi, poi soli aggregati. Basi giuridiche e bilanciamenti: LIA e DPIA richiamate nelle note di compliance.

Metriche di performance

Validazione out-of-time su pratiche 2024-2025: AUC 0.79, KS 0.42, calibrazione entro il 5% di scarto per classe. Per segmento: microimprese sotto i 5 addetti AUC 0.74, imprese con meno di 24 mesi di storia AUC 0.71, limiti dichiarati e gestiti con instradamento a istruttoria. Condizioni di validità: distribuzione degli input stabile (PSI sotto 0.2) e copertura open banking di almeno 12 mesi; fuori da queste condizioni le metriche non sono garantite e il fallback è l'istruttoria manuale.

Valutazioni di equità

Metrica scelta: equal opportunity (parità di tasso di veri positivi) sui gruppi definiti da genere e fascia d'età del titolare effettivo, con il territorio monitorato come proxy. Motivazione: in un sistema di allocazione di opportunità l'errore più grave è negare credito a chi lo avrebbe ripagato, e i teoremi di impossibilità della letteratura sulla fairness impongono di scegliere; la scelta è documentata nel verbale G1 della v3.0. Esiti v3.2: gap 0.03 (genere), 0.04 (età), sotto la soglia di escalation 0.05; screening quattro quinti superato su tutti i segmenti. Area di attenzione: imprese sotto i 24 mesi, dove il gap combinato con la minore accuratezza richiede il monitoraggio dedicato previsto dal piano.

Limitazioni note e condizioni di degrado

Storico limitato su settori emergenti (energie rinnovabili, economia digitale); sensibilità dimostrata agli shock macroeconomici (il drift del 2022 sui costi energetici ha richiesto la ricalibrazione della v2); non validato per importi oltre 250.000 euro; degrado misurabile quando la copertura open banking scende sotto i 12 mesi.

Monitoraggio, supervisione, compliance

Monitoraggio: PSI mensile su input e score, gap di equità mensile per segmento, backtesting dei default a 12 mesi, review G4 trimestrale. Supervisione umana: classi 4-6 a istruttoria obbligatoria; l'analista vede score, driver principali e limiti dichiarati, può ribaltare la raccomandazione con motivo tracciato e può sospendere l'uso del modello via escalation al Comitato. Compliance: AI ad alto rischio (Annex III 5(b)); CrediPulse provider e deployer; fascicolo tecnico FT-CS-PMI-3.2; FRIA 2026-07 (appendice F); registrazione UE pianificata in roadmap.

Versione	Data	Modifiche principali
3.2	2026-06-15	Ricalibrazione annuale; esame bias esteso ai segmenti d'età; soglie PSI riviste
3.1	2025-11-10	Integrazione della seconda fonte open banking; retraining nell'envelope dichiarato
3.0	2025-03-20	Rebuild dalla famiglia v2: nuova pipeline dati, metrica di equità formalizzata al G1

Tabella E.2 - Registro delle versioni.

Appendice F - FRIA compilata: sistema di scoring CS-PMI

Istanza d'uso del template D. Scenario simulato; il giudizio applica il criterio di falsificabilità del capitolo 8.

Campo	Valore
Sistema valutato	CS-PMI v3.2 (MDL-2024-003), scoring creditizio PMI
Deployer	CrediPulse S.p.A. (anche provider)
Processo	Concessione credito digitale; uso continuativo, decine di migliaia di valutazioni l'anno
Valutatore / data	DPO, con Compliance e business credito - 2026-07
Esito	Via libera condizionato (condizioni e follow-up sotto)

Tabella F.1 - Intestazione della valutazione.

Contesto e soggetti interessati

Il sistema valuta imprese, ma incide su persone fisiche: titolari effettivi, soci di microimprese, garanti. Per una ditta individuale la distinzione tra merito dell'impresa e merito della persona è puramente formale. Gruppi che meritano attenzione rafforzata: imprenditori di origine straniera (esposti alla proxy discrimination territoriale e di storico), imprese giovani e fondatori giovani (penalizzati dalla scarsità di storia creditizia), attività in aree economicamente svantaggiate (dove il segnale territoriale è più forte del merito individuale).

Valutazione per diritto

Diritto	Meccanismo di impatto	Prob.	Gravità
Non discriminazione (art. 21 Carta)	Proxy discrimination su territorio e storico; feedback loop sui gruppi storicamente esclusi	Media	Alta
Protezione dei dati (art. 8 Carta)	Profilazione su quattro fonti; possibile inferenza di attributi sensibili da dati ordinari	Media	Alta
Libertà d'impresa (art. 16 Carta)	L'accesso al credito condiziona l'attività economica; un diniego sistematico ha effetti espulsivi	Bassa	Alta
Tutela effettiva (art. 47 Carta)	Senza spiegazione comprensibile la decisione è incontestabile di fatto	Alta	Media

Tabella F.2 - Diritti impattati, con probabilità e gravità motivate nel testo.

Le due valutazioni più severe si motivano così: sulla non discriminazione, il meccanismo è strutturale e documentato (RC01) e la gravità è alta perché il danno è sistematico e invisibile alla singola vittima; sulla tutela effettiva, la probabilità è alta perché, allo stato, la spiegazione individuale ex art. 86 non è operativa: senza motivi comprensibili, il diritto a contestare esiste sulla carta e non in pratica.

Riuso della DPIA e misure organizzative

La DPIA 2024 resta valida su flussi, basi giuridiche e misure di sicurezza del trattamento; la FRIA aggiunge l'analisi per diritto, i gruppi vulnerabili e le misure di governance. Le misure a tutela sono quelle del framework: metrica di equità come criterio di gate con monitoraggio mensile disaggregato (RC01), sorveglianza umana attuata secondo le istruzioni d'uso come richiede l'art. 27(1)(e), con autorità reale di override e istruttoria obbligatoria nelle classi intermedie, logging decisionale completo, canale di reclamo con presa in carico tracciata, riesame trimestrale del registro dei rischi.

Gap, conclusioni e follow-up

Gap	Azione	Owner	Scadenza
Spiegazione individuale non operativa (art. 86)	Template di motivazione per causale; test di comprensibilità su utenti reali	Business credito	3-6 mesi
Formazione dei revisori assente	Formazione su limiti del modello e automation bias, con registro	Responsabile AI	3-6 mesi
Canale di reclamo generico	Procedura dedicata alle decisioni automatizzate con SLA di risposta	DPO	0-3 mesi

Gap	Azione	Owner	Scadenza
Monitoraggio gruppi vulnerabili non formalizzato	Segmenti d'attenzione espliciti nel piano di monitoraggio	Model Owner	0-3 mesi

Tabella F.3 - Gap e azioni correttive.

Conclusione: via libera condizionato alla chiusura delle azioni in tabella F.3 nei termini indicati. La valutazione si riapre se: il gap di equità supera la soglia per due mesi consecutivi, i reclami fondati su decisioni automatizzate mostrano ricorrenza su un gruppo, l'uso si estende a nuovi prodotti o mercati, o il monitoraggio post-market contraddice le assunzioni di questa analisi. Esito notificato all'autorità di vigilanza del mercato come previsto dall'art. 27. La valutazione avrebbe concluso per il no in un caso preciso: l'uso del sistema in decisione interamente automatica senza istruttoria nelle classi intermedie e senza spiegazione individuale operativa; è la configurazione che il framework vieta.